

Cybersecurity

Exploring Exploitation

Lesson 15.3



Learning Objectives

By the end of today's class, you will be able to:

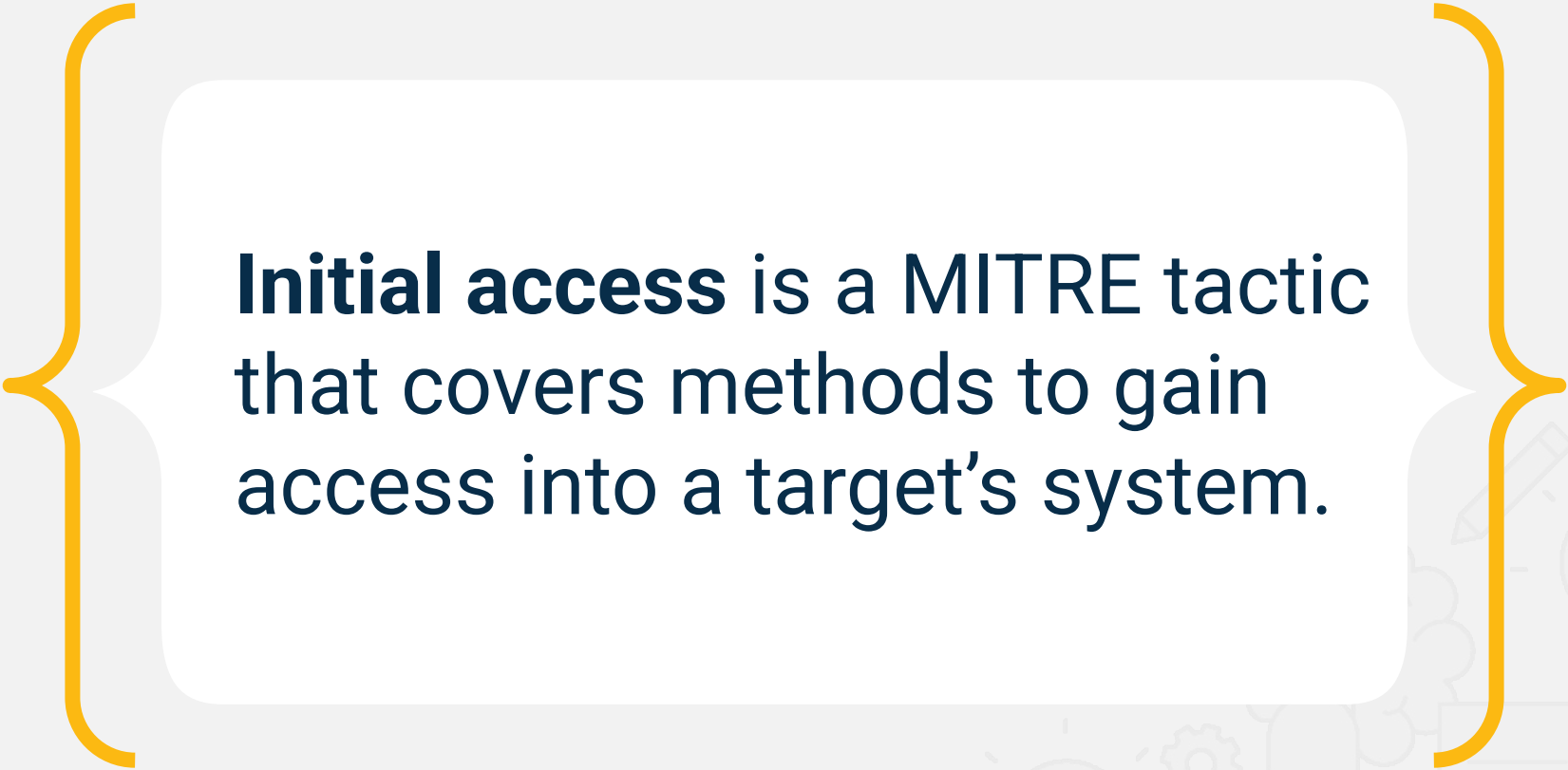
- 1 Understand what command and control (C2) is and how it fits into a penetration tester's toolkit.
- 2 Use Metasploit to automate exploitation activities.
- 3 Explain what privilege escalation is and how it fits into the attack cycle.
- 4 Perform basic privilege escalation tasks.



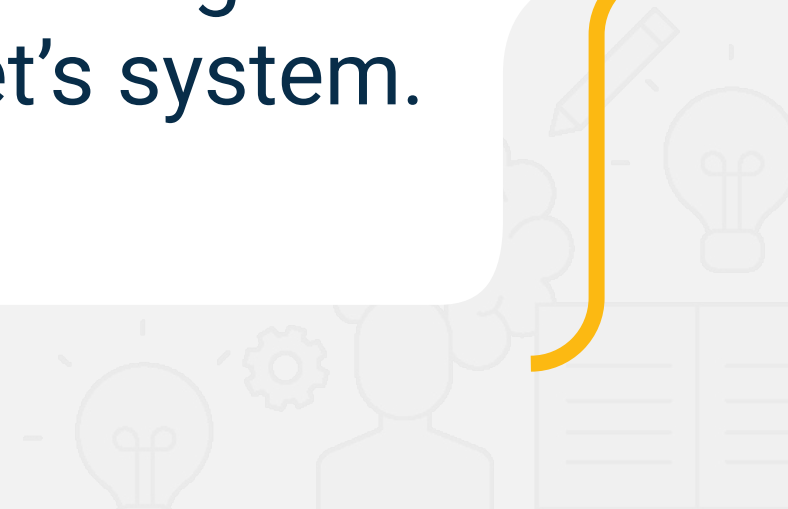
Welcome



Let's recap

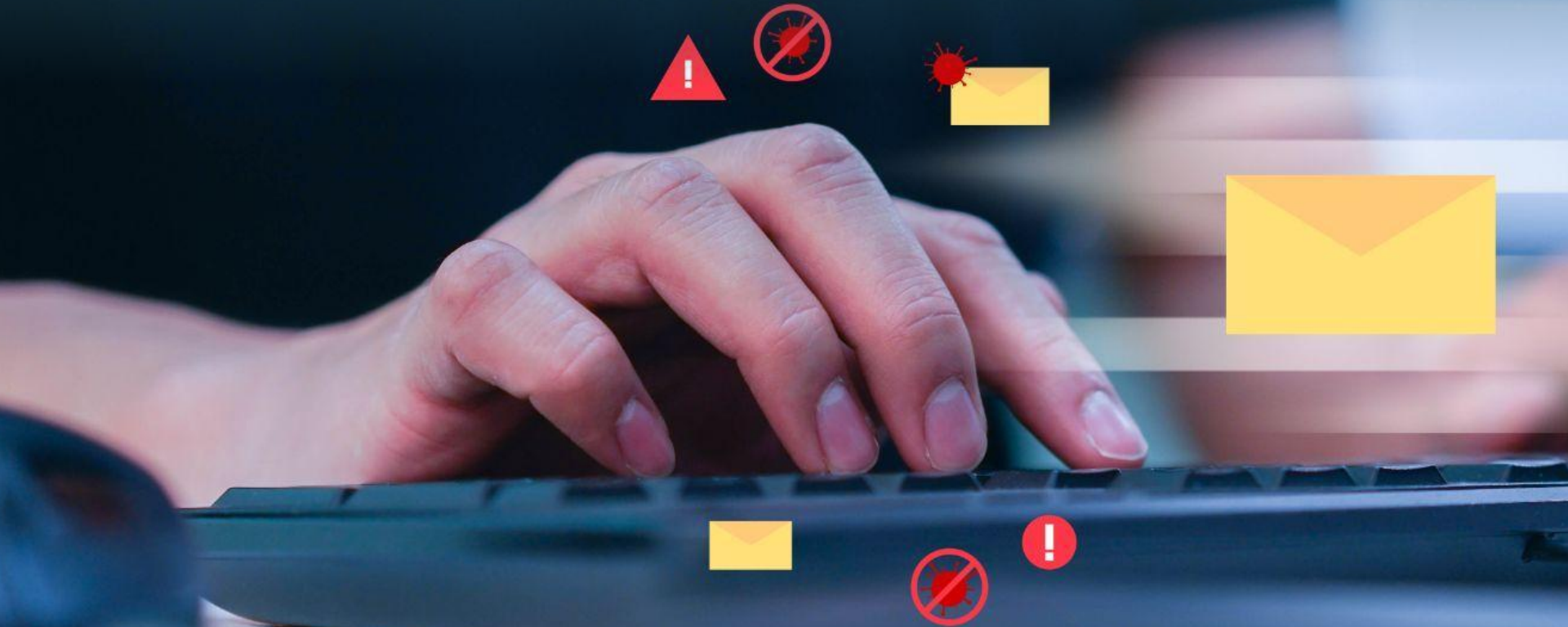


Initial access is a MITRE tactic that covers methods to gain access into a target's system.



Phishing

Phishing is the most commonly used initial access method. It leverages human error by crafting misleading and convincing fraudulent emails.



Remote services through valid accounts

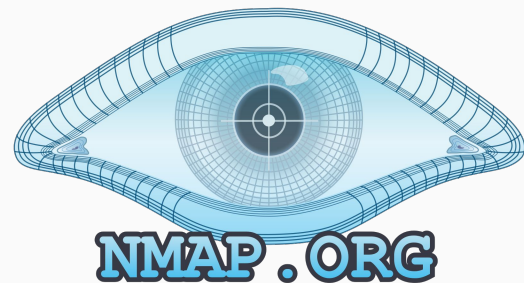
is another initial access method, where the attacker uses existing real user accounts to gain access through a remote service, such as a VPN.





Day 2 Recap

Scanning is the second phase after Reconnaissance. Scanning utilizes tools to gather information such as network information and potential vulnerabilities.



We often use the tools **Hping**, **Nmap**, **Zenmap**, and **Nessus** to conduct scanning.

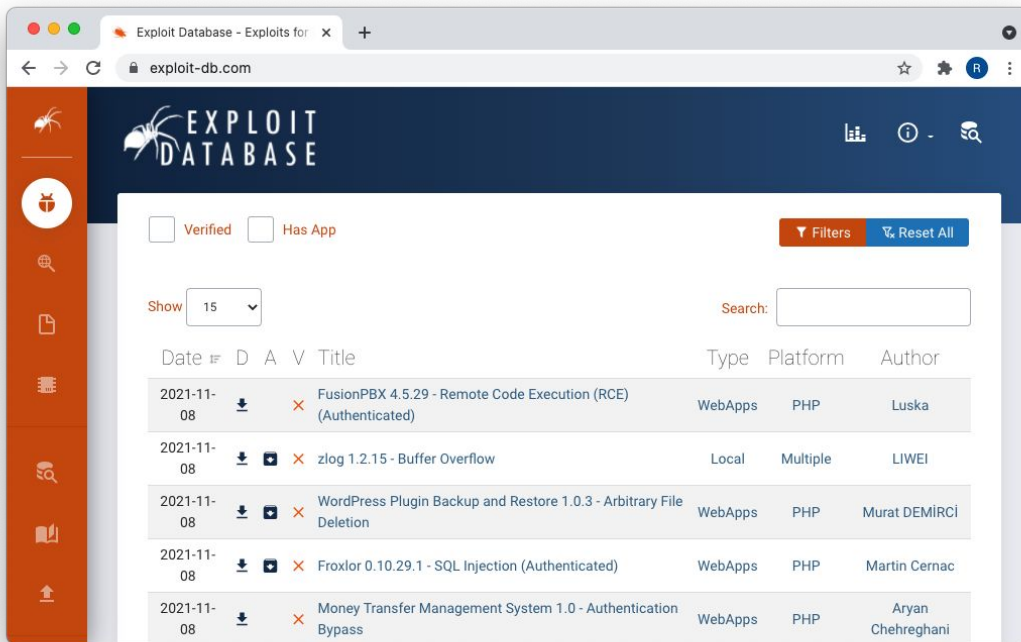
NSE (Nmap scripting engine) scripts are scripts that work with Nmap or Zenmap and are commonly used to test whether a service is vulnerable to an exploit.



Day 2 Recap

Exploit-DB.com is a popular online database that contains publicly disclosed exploits, cataloged according to their Common Vulnerability and Exposure (CVE) identifier.

SearchSploit is a command line utility for Exploit-DB that allows you to take an offline copy of the entire Exploit Database with you wherever you go.



Exploitation

Exploited access to the machine is typically granted in the form of terminal access, known as a **shell**. There are two types of shells:

Bind shell

The remote host opens a port to which the current host can connect.

The current local host then connects to that remote host's port.

Reverse shell

The remote host connects back to a port on the local host.

The Five Stages of Pen Testing Recap

On Day 1, we introduced the five stages of a pen test engagement:

01A	Planning	Define the purpose and scope of the test, and sign all legal contracts.
01B	Reconnaissance	Obtain publicly available information about your target.
02	Scanning	Use tools to run a scan against your target to gather information, such as open ports, and run services to determine potential vulnerabilities.
03	Exploitation	Attack the vulnerabilities discovered in the previous steps to gain access to the target.
04	Post Exploitation	Gather valuable information from the compromised systems.
05	Reporting	Report on the previous five steps to provide a summary of actions taken, findings, and recommended mitigations.

We ended Day 2's lesson by starting the **Exploitation phase (Phase 3)** and manually exploiting a remote host's vulnerable service to obtain a reverse shell.

- Today, we will begin by covering C2 and Metasploit.
- Then, we'll use Metasploit to exploit another vulnerability and gain another shell on a remote host.



Planning and
reconnaissance

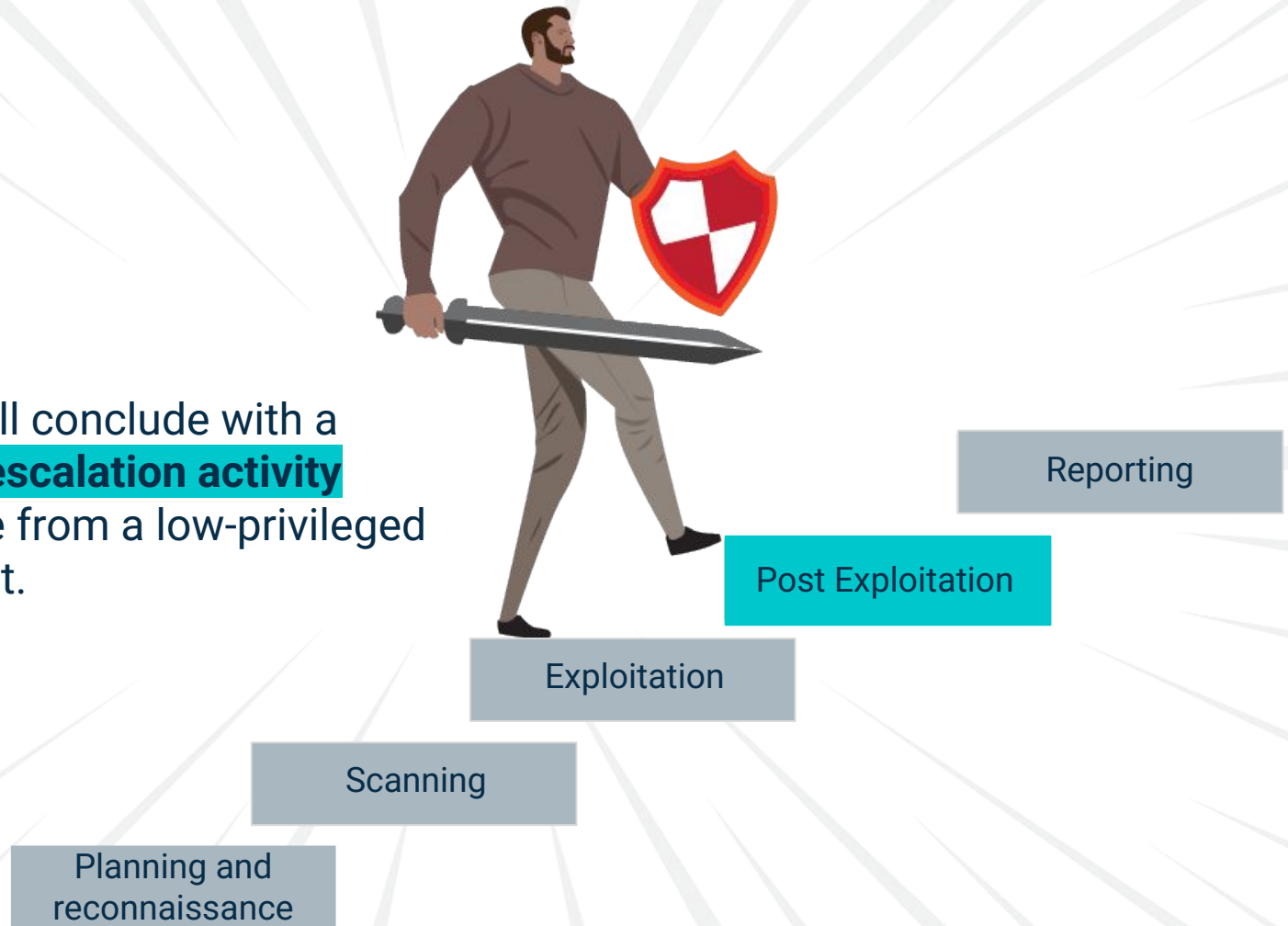
Scanning

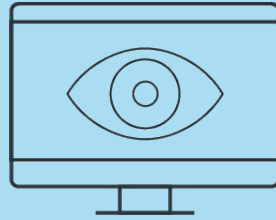
Exploitation

Post exploitation

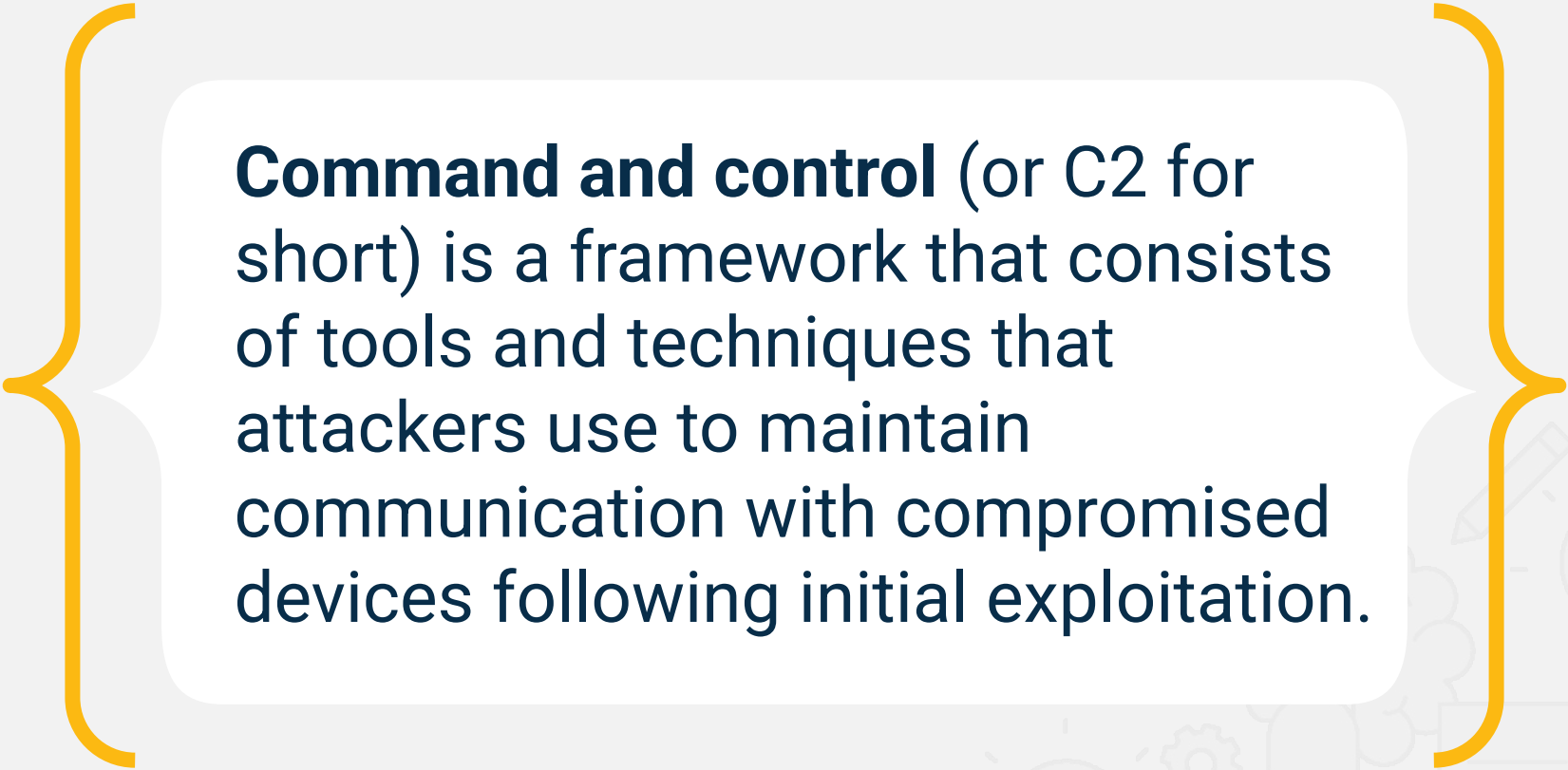
Reporting

The day will conclude with a **privilege escalation activity** to escalate from a low-privileged user to root.

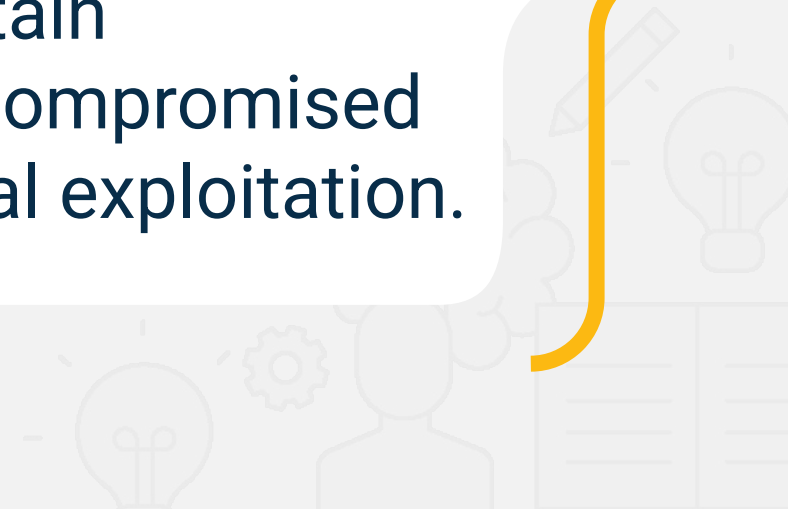




Command and Control



Command and control (or C2 for short) is a framework that consists of tools and techniques that attackers use to maintain communication with compromised devices following initial exploitation.

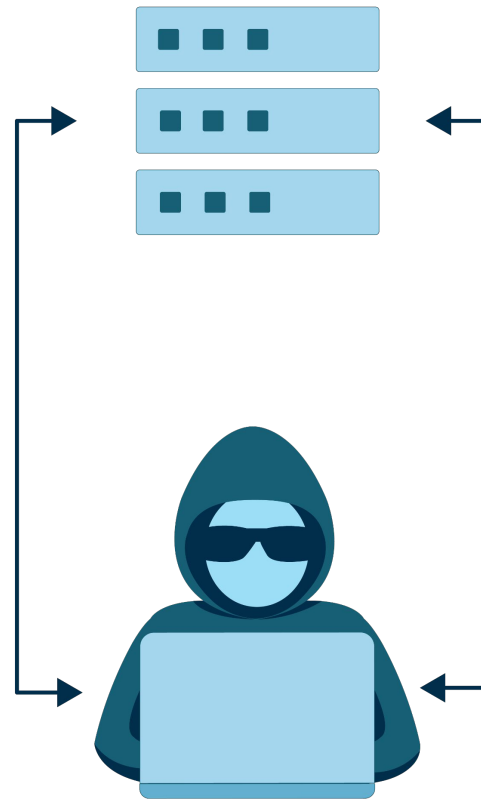


Command and Control

C2 frameworks come in various languages and are developed by individuals and companies alike.

The majority of C2 frameworks are open source, meaning that they're free and the public can read the source code.

We will learn about a variety of C2 frameworks; however, for the purposes of this class, we'll use the **Metasploit** framework.



Metasploit is a popular and open-source C2 framework created by Rapid7.

RAPID7
metasploit®

Get Started >

Contribute >

Docs >

Help >

Download

Join Us On

Slack

IRC

GitHub

Twitter

metasploit®

The world's most used penetration testing framework

Knowledge is power, especially when it's shared. A collaboration between the open source community and Rapid7, Metasploit helps security teams do more than just verify vulnerabilities, manage security assessments, and improve security awareness; it empowers and arms defenders to always stay one step (or two) ahead of the game.

★ Star 25,556



Get Metasploit

OPEN SOURCE

Metasploit
Framework

Download

Latest

COMMERCIAL SUPPORT

Metasploit
Pro

Free Trial

Latest

Get visibility into your network with Rapid7's InsightVM

[30-Day Trial](#)

[Compare Features](#) >

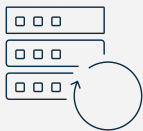
[View More Projects](#) >

Command and Control

C2 frameworks work within a C2 architecture, which consists of:

C2 Server

The attacker's server, where the attacker communicates with the compromised machines.



C2 Agents

The payload that is run on the compromised machine in order to open up a connection back to the C2 server.



C2 Architecture

A C2 architecture is how the C2 server is set up and how the agent communicates back to the C2 server

-  In order to compromise a machine, the C2 agent must be running on it.
-  Fortunately, most C2 frameworks have a built-in capability to generate an agent.
-  The agent typically runs as a process and needs to run continuously for communications to flow consistently between it and the C2 server.
-  Metasploit's agent is built into the code of its exploits.

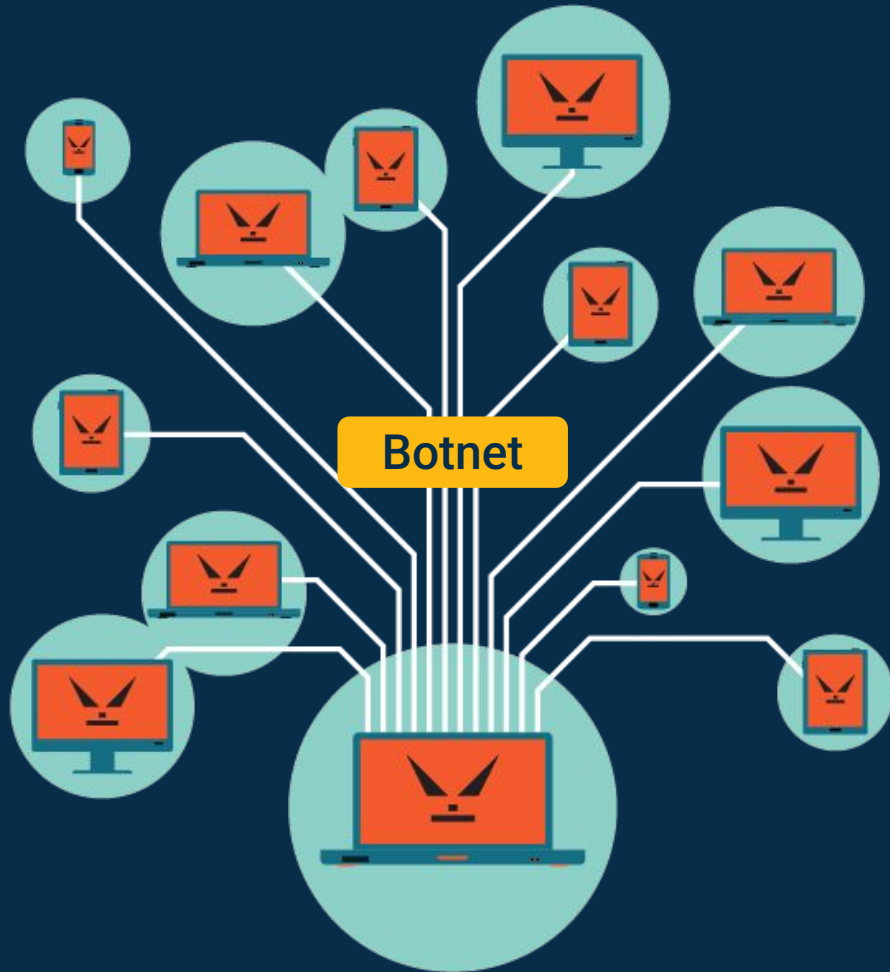
Zombies and Botnets

Once the machine has the C2's agent running on it, it is compromised—sometimes referred to as a **zombie**.



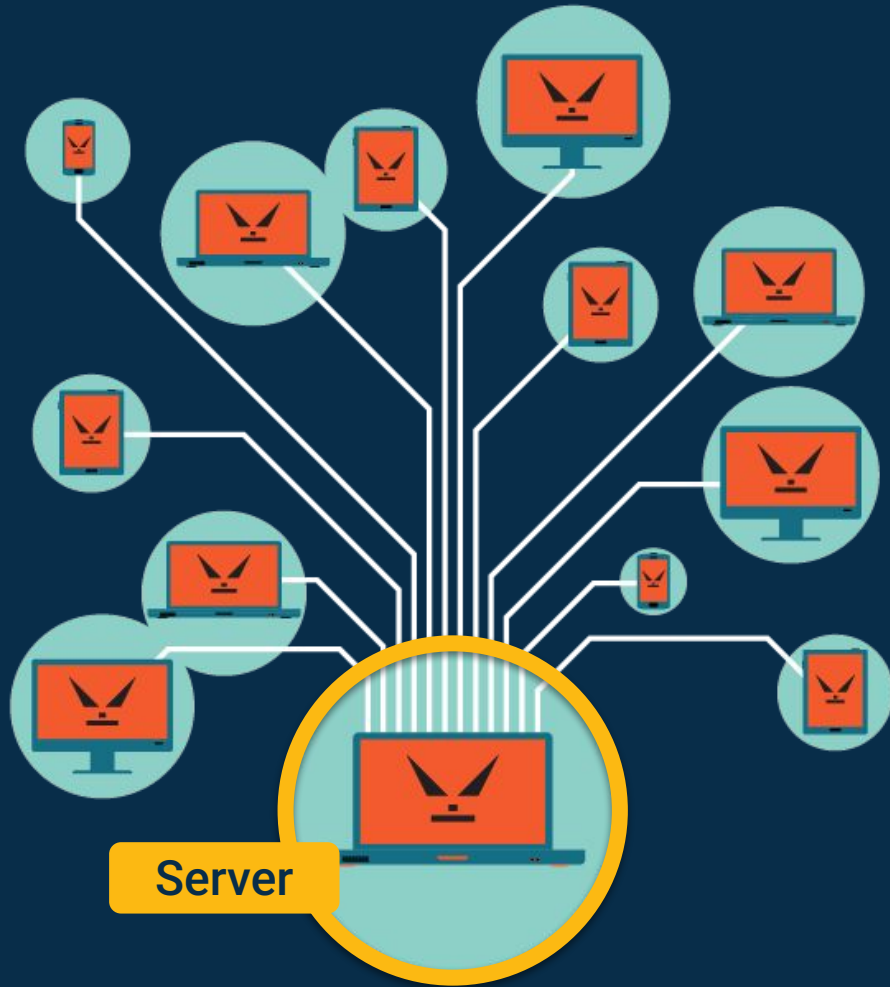
Zombies and Botnets

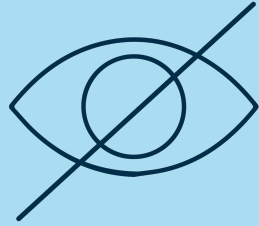
Multiple zombies form a **botnet**.



Zombies and Botnets

The entire botnet of compromised machines is controlled through the single C2 server.





Concealing the C2 Server



One of a penetration tester's important tasks is to **conceal** the C2 server from detection.

Concealing the C2 Server

Method 1

Redirection
through proxies

Method 2

Utilizing multiple
channels

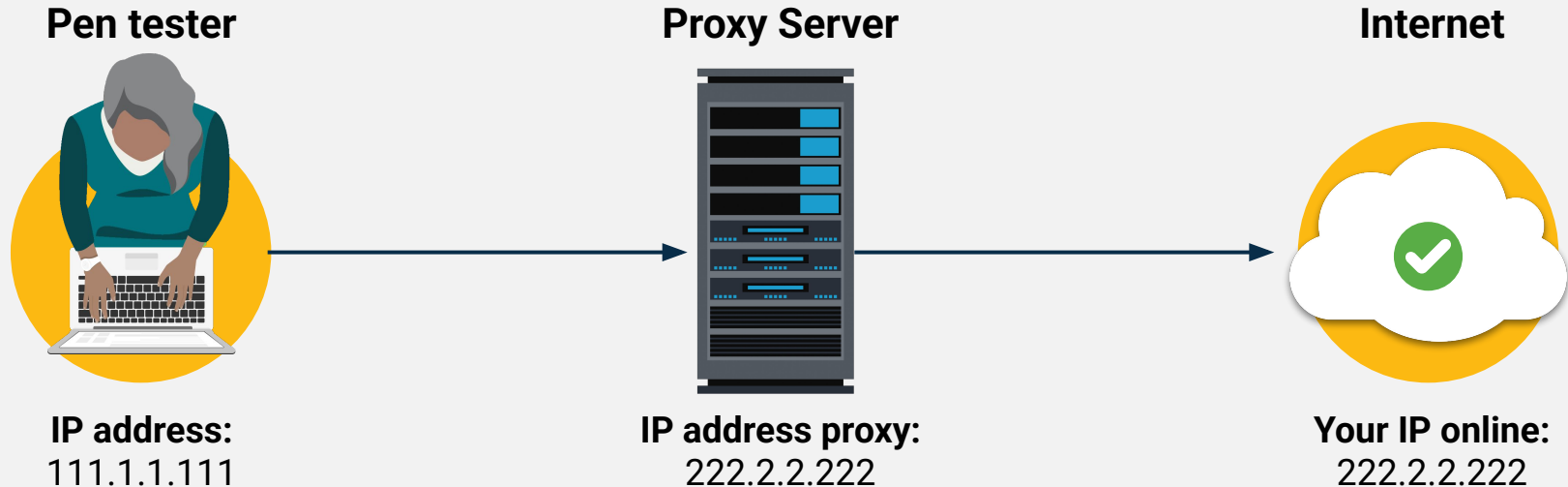
Method 3

Utilizing multiple
C2 frameworks

Method 1: Redirection Through Proxies

We will use a host that directly connects to the C2 server for simplicity. However, in a real penetration test, that would be a poor decision, because a simple packet collection would detect the C2 server IP, which could be blocked.

To avoid this detection, a pen tester could have the C2 redirected through proxies.

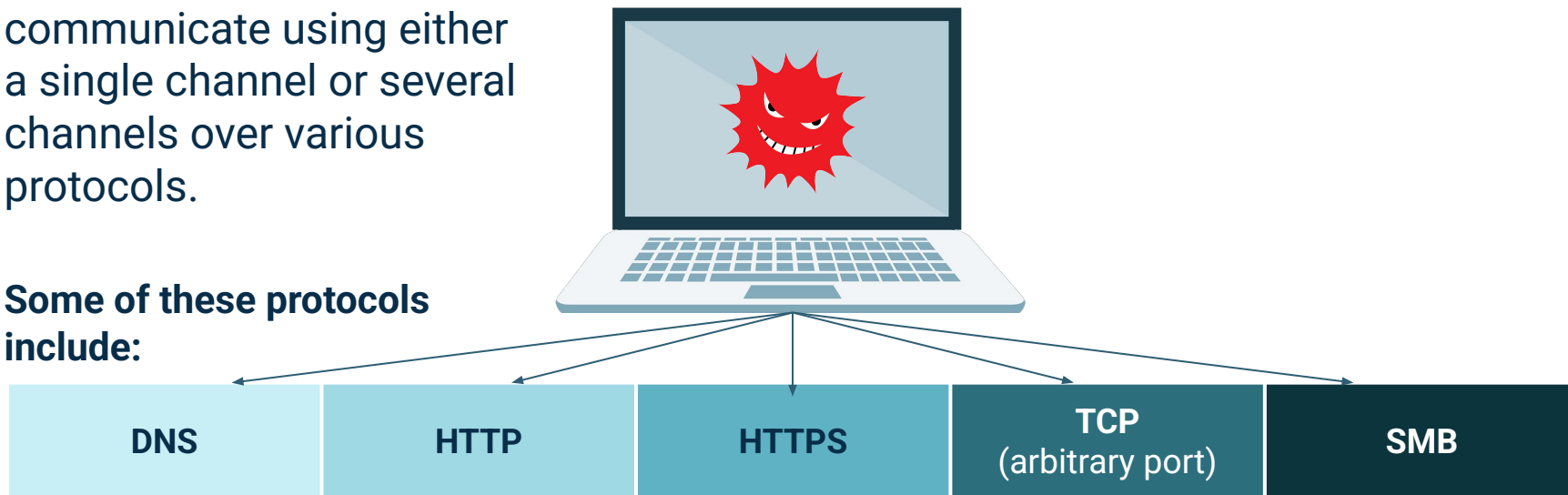


Method 2: Utilizing Multiple Channels

Another method that most C2 frameworks support is having the agent use multiple ways, or **channels**, to communicate back to the server.

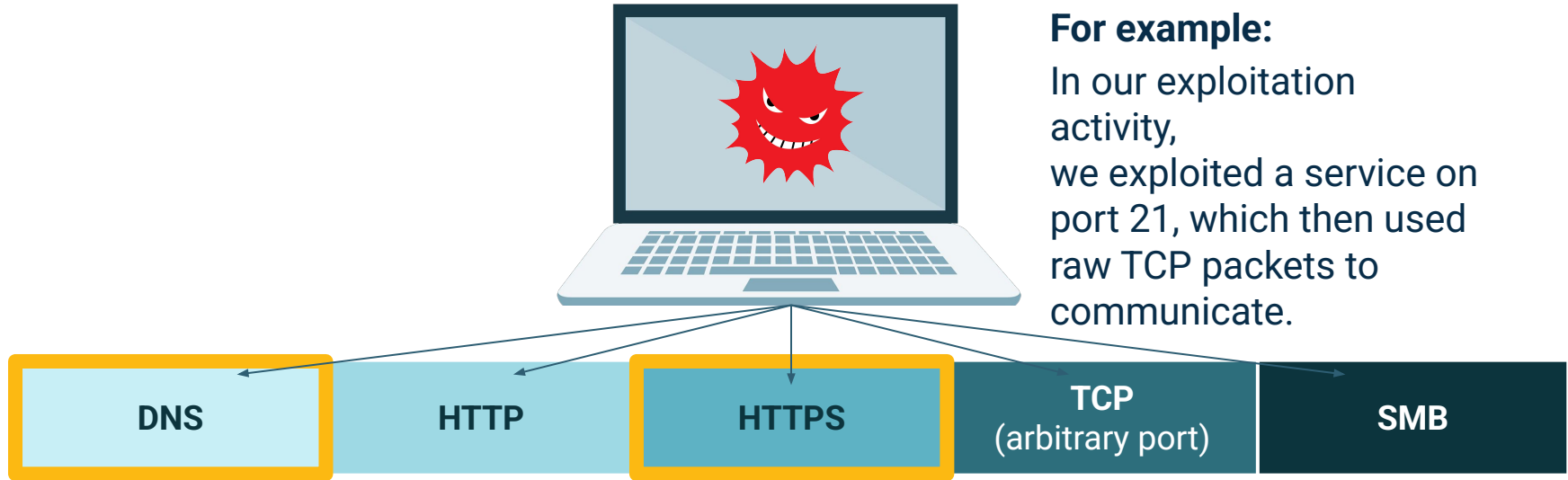
A compromised host can communicate using either a single channel or several channels over various protocols.

Some of these protocols include:



Method 2: Utilizing Multiple Channels

The protocol used is dependent on the target's network firewall egress rules. Most egress rules allow HTTP/S and DNS outbound, which is why those channels are commonly used for C2 communication.



While we will only use the **Metasploit** C2 framework in this class, most C2 frameworks are open source, which allows you to use them freely.

It's good practice to have multiple C2 frameworks available for a penetration test or red team engagement.



Method 3: Utilizing Multiple C2 Frameworks

C2 frameworks each have their own “fingerprints” or “indicators of compromise.”

For example, **Metasploit's** payload and agent generator, `msfvenom`, will generate a payload in a specified format (e.g., `.exe`).

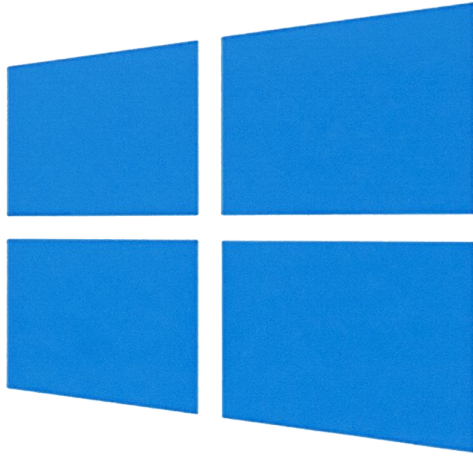
These payloads have well-known signatures, and many antivirus products will alert on them and kill the payload.

In an event where a certain AV product is killing the payload during or after execution, it may be a good idea to switch C2 frameworks.



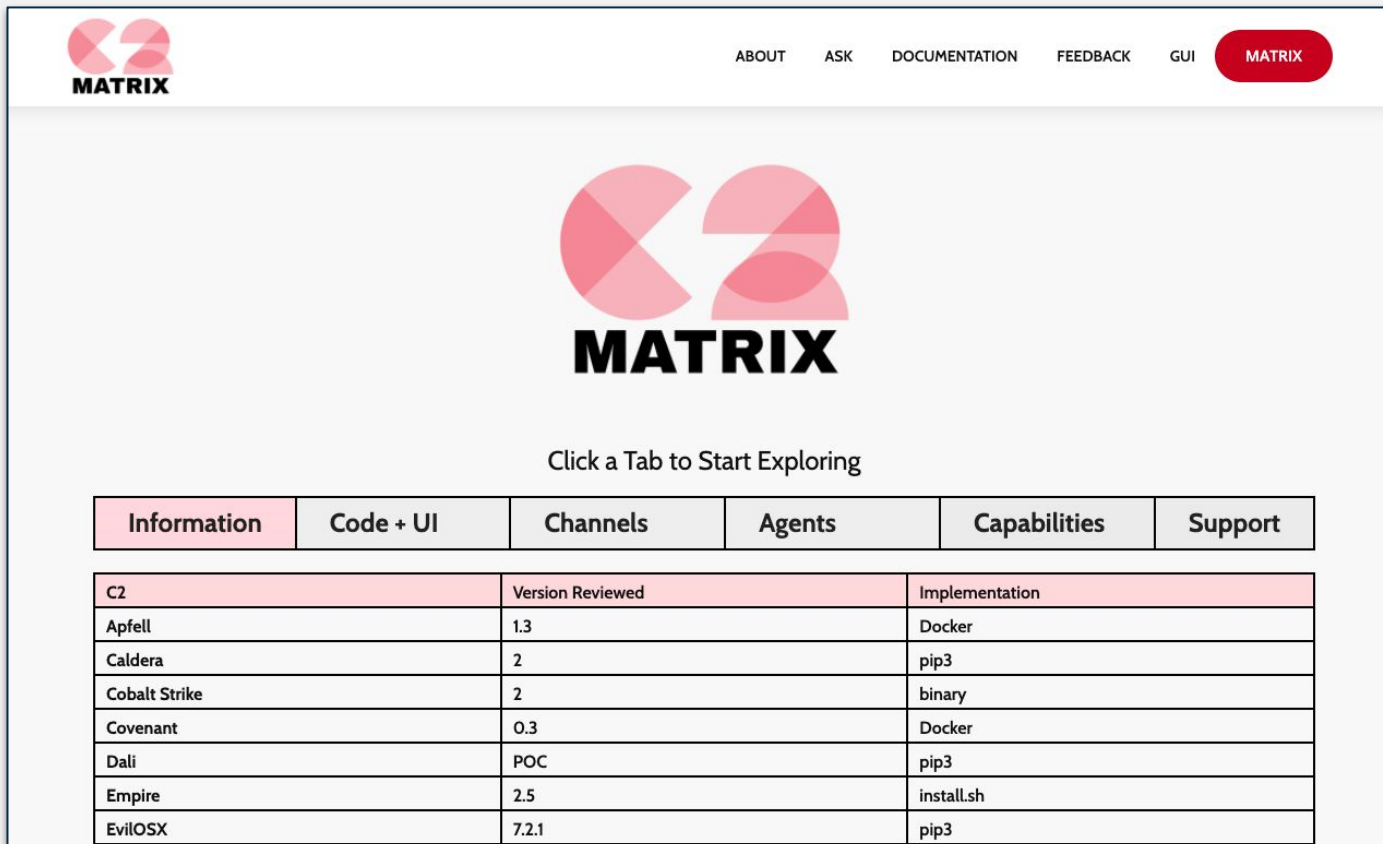
Method 3: Utilizing Multiple C2 Frameworks

Not all C2 frameworks support every OS. Some only support Windows, and not Linux, for example.



It's good to have a secondary C2 framework that supports an OS if the primary C2 framework doesn't.

To select the best C2 framework for a given project's requirements, a penetration tester could use the website C2 Matrix.

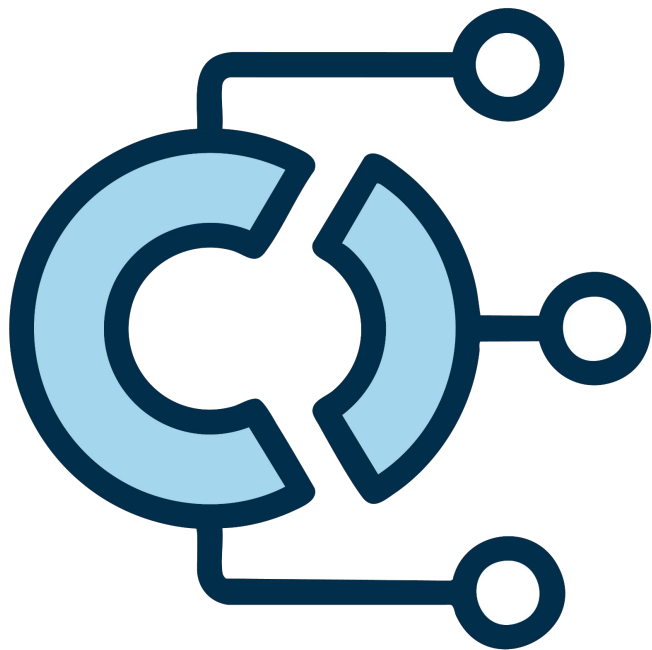


The screenshot shows the C2 Matrix website. At the top left is the C2 Matrix logo. The top navigation bar includes links for ABOUT, ASK, DOCUMENTATION, FEEDBACK, and GUI, followed by a red button labeled MATRIX. The main content area features a large C2 Matrix logo and the text "Click a Tab to Start Exploring". Below this is a horizontal tab bar with six tabs: Information, Code + UI, Channels, Agents, Capabilities, and Support. The "Information" tab is selected. Below the tabs is a table with three columns: C2, Version Reviewed, and Implementation. The table lists several C2 frameworks and their details.

C2	Version Reviewed	Implementation
Apfell	1.3	Docker
Caldera	2	pip3
Cobalt Strike	2	binary
Covenant	0.3	Docker
Dali	POC	pip3
Empire	2.5	install.sh
EvilOSX	7.2.1	pip3

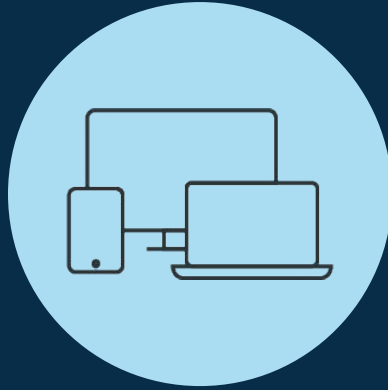


Demonstration Scenario



For this demonstration, we need to select a C2 framework with the following requirements:

- It must support the channels of **HTTP** and **SMB**.
- It must support Windows.
- It must provide logging.



Instructor Demonstration

C2 Matrix

C2 Matrices

Information	Contains the version number reviewed.
Code + UI	Contains the server and agent language used.
Channels	Contains the supported channels.
Agents	Contains the supported OS.
Capabilities	Contains other available capabilities.
Support	Contains the additional support provided.

Summary

Can you define the following terms?

01

C2

02

C2 Architecture

03

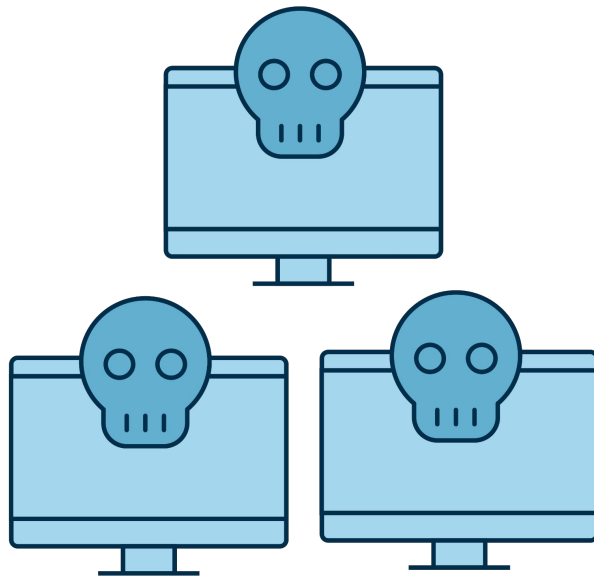
C2 Agent

04

Zombie

05

Botnet





Activity:

C2 Research

In this activity, you will continue to play the role of pen testers conducting an engagement on MegaCorpOne.

- Research various C2 frameworks by using the C2 Matrix website, and suggest the best C2 framework for your current assessment on MegaCorpOne.

Suggested Time:
15 Minutes



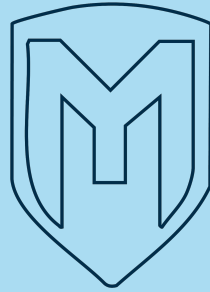


Time's up!
Let's review



Questions?





Metasploit



Metasploit

C2 Framework Overview



- Created in 2003 and is owned by Rapid7
- Free version and a professional version
- Metasploit contains a suite of tools for hacking servers
- Metasploit also has tools for port and service scanning as well as enumeration
- Save the results of scans to a database



Metasploit

The main Metasploit tools that we'll focus on are:



MSFconsole

Meterpreter

msfvenom



Metasploit

Meterpreter

A Linux-style shell that Metasploit launches when you successfully break into a target machine. This **runs on the target machine**, not your local machine.

```
meterpreter > help
```

```
Core Commands
```

```
=====
```

Command	Description
-----	-----
?	Help menu
background	Backgrounds the current session
channel	Displays information about active channels
...snip...	



Metasploit

msfvenom

Allows the operator to craft the malicious agents and payloads that will be used to communicate back with Metasploit.

These agents and payloads can be created in several formats:

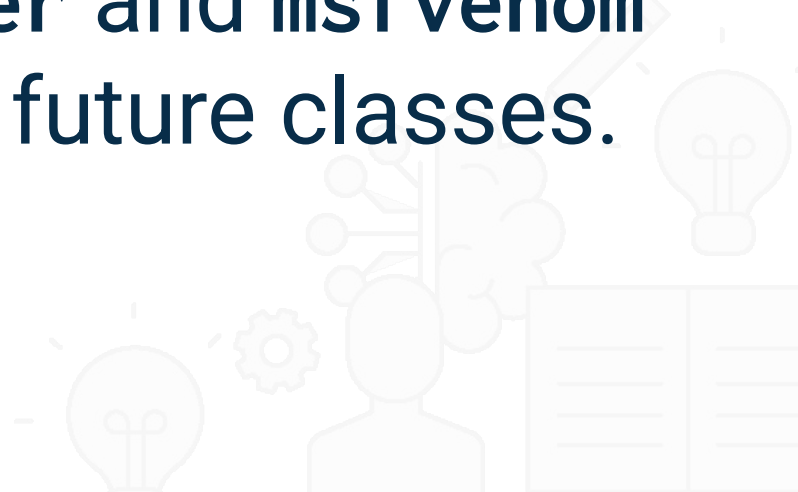
- .exe
- .py
- bash

```
File Edit View Search Terminal Help
root@kali:~# msfvenom -h
Error: MsfVenom - a Metasploit standalone payload generator.
Also a replacement for msfpayload and msfencode.
Usage: /usr/bin/msfvenom [options] <var=val>

Options:
-p, --payload <payload>      Payload to use. Specify a '-' or stdin to use custom payloads
--payload-options             List the payload's standard options
-l, --list [type]            List a module type. Options are: payloads, encoders, nops, all
-n, --nopsled <length>      Prepend a nopsled of [length] size on to the payload
-f, --format <format>       Output format (use --help-formats for a list)
--help-formats               List available formats
-e, --encoder <encoder>      The encoder to use
-a, --arch <arch>            The architecture to use
--platform <platform>       The platform of the payload
--help-platforms            List available platforms
-s, --space <length>        The maximum size of the resulting payload
--encoder-space <length>     The maximum size of the encoded payload (defaults to the -s value)
-b, --bad-chars <list>      The list of characters to avoid example: '\x00\xff'
-i, --iterations <count>    The number of times to encode the payload
-c, --add-code <path>       Specify an additional win32 shellcode file to include
-x, --template <path>       Specify a custom executable file to use as a template
-k, --keep                   Preserve the template behavior and inject the payload as a new thread
-o, --out <path>            Save the payload
-v, --var-name <name>       Specify a custom variable name to use for certain output formats
--smallest                   Generate the smallest possible payload
-h, --help                   Show this message
root@kali:~#
```



Today, we will focus on **MSFconsole**. We'll explore **Meterpreter** and **msfvenom** in depth in future classes.



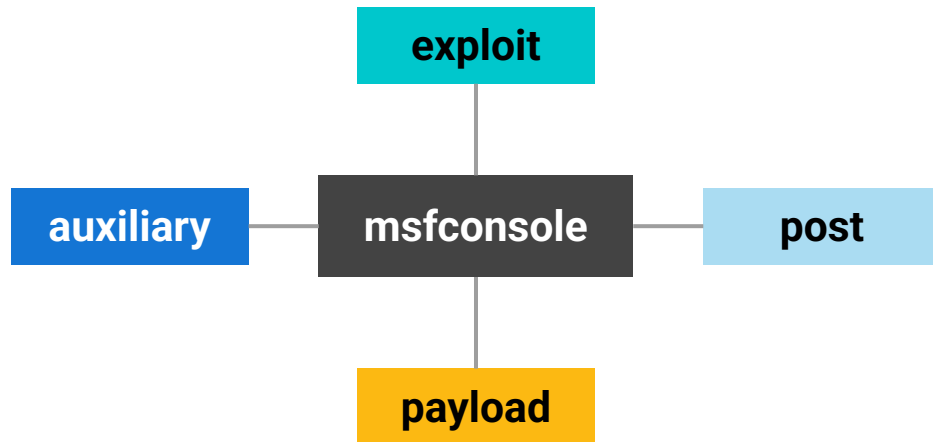


Metasploit

Metasploit Modules

MSFconsole is a unified interface that has a variety of function, referred to as **modules**.

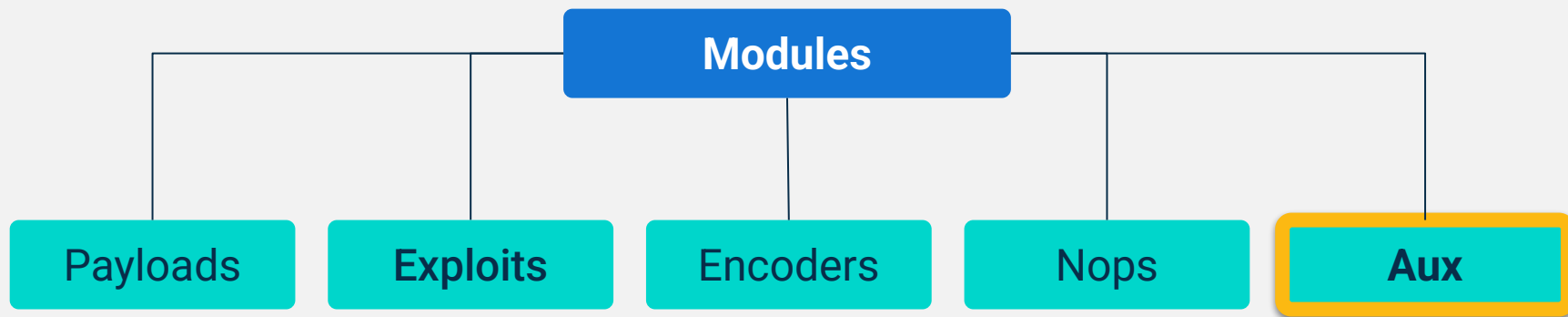
- **Auxiliary**- Information gathering, enumeration, and port scanning
- **Exploit**- Used to deliver exploit code
- **Post**- Post exploitation tools
- **Payload**- Create malicious payloads
- **Encoder**- Ensure payloads make it to destination intact





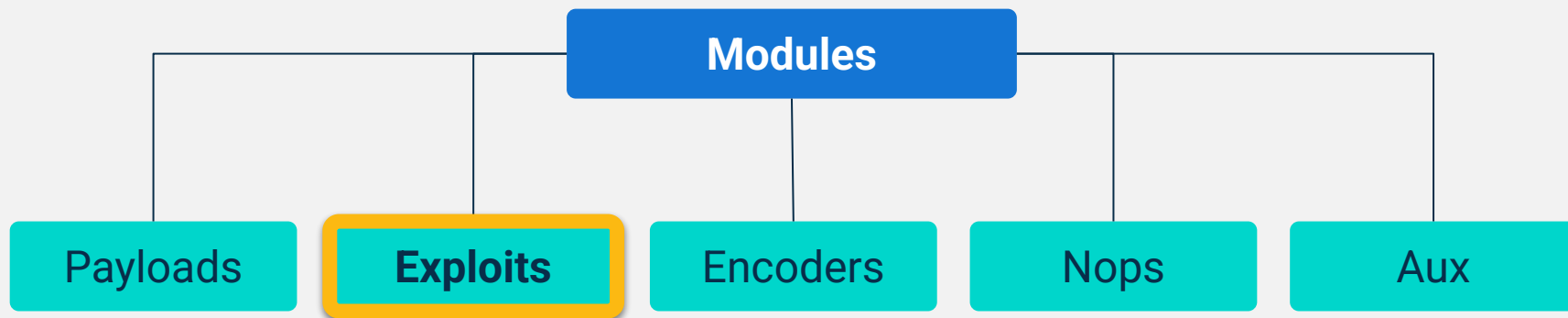
The choice of module depends on what you're trying to **accomplish**.

If **recon** is the goal...



...then an auxiliary module is typically the right solution, as they're primarily for recon, scanning, and fuzzing.

If the goal is to **exploit a vulnerability...**



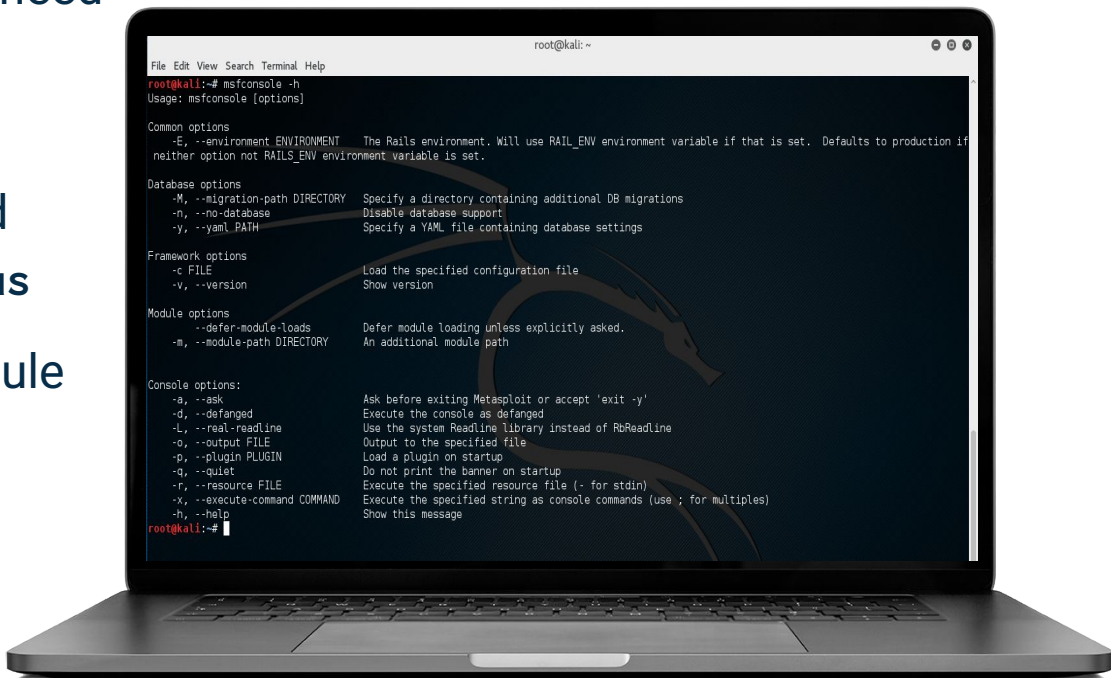
...then an exploit module is appropriate,
as it actively tries to exploit the vulnerability.

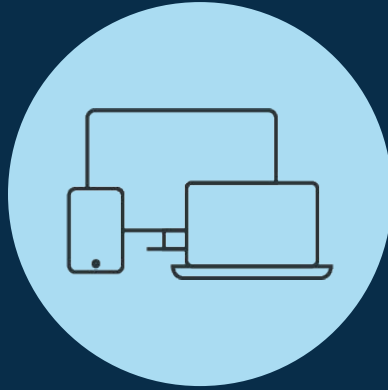


Demonstration Scenario

We have determined through a previous scan that **FTP** may be running. We need to:

- Launch **MSFconsole**
- Search for the commonly used auxiliary module **ftp/anonymous**
- Select the **ftp/anonymous** module
- Set the required values for the **ftp/anonymous** module
- **Execute** the module





Instructor Demonstration

Metasploit



Let's recap

Metasploit is a popular C2 framework that contains a suite of tools for enumerating and exploiting servers and other networked devices.

RAPID7
metasploit®

[Get Started](#) >

[Contribute](#) >

[Docs](#) >

[Help](#) >

[Download](#)

Join Us On

 [Slack](#)

 [IRC](#)

 [GitHub](#)

 [Twitter](#)

metasploit®

The world's most used penetration testing framework

Knowledge is power, especially when it's shared. A collaboration between the open source community and Rapid7, Metasploit helps security teams do more than just verify vulnerabilities, manage security assessments, and improve security awareness; it empowers and arms defenders to always stay one step (or two) ahead of the game.

★ Star 25,556



Get Metasploit

OPEN SOURCE

Metasploit
Framework

[Download](#)

Latest

COMMERCIAL SUPPORT

Metasploit
Pro

[Free Trial](#)

Latest

Get visibility into your network with Rapid7's InsightVM

[30-Day Trial](#)

[Compare Features](#) >

[View More Projects](#) >

Metasploit

The main tools of Metasploit are:

MSFconsole

The main interface for Metasploit, which runs on your local machine.

Meterpreter

A Linux-style shell that runs on the machines you compromise.

msfvenom

Allows the operator to craft the malicious agents and payloads that will be used to communicate back with Metasploit.

Metasploit Modules

MSFconsole is a unified interface for a variety of functions.

The five main types of Metasploit modules are:

Auxiliary modules	Used for information gathering, enumeration, and port scanning.
Exploit modules	Generally used to deliver exploit code to a target system.
Post modules	Offer post-exploitation tools.
Payload modules	Used to create malicious payloads to use with an exploit.
Encoder modules	Used to ensure that payloads make it to their destination intact.

Metasploit Commands

msfconsole	Launches MSFconsole from the command line.
Show + module type	Displays all the available modules (e.g., <code>show auxiliary</code>).
Search + keyword	Searches for modules based on a keyword.
Use + module name	Selects a specific module (e.g., <code>use scanner/ftp/anonymous</code>).
info	Displays the module details as well as the required and optional options.
options	Just displays the options available for the module.
exploit OR run	Runs the module.



Questions?





Activity:

Metasploit

In this activity, you will continue to play the role of pen testers conducting an engagement on MegaCorpOne.

- MegaCorpOne has given you permission to exploit any vulnerable service you find, as long as you document your actions.
- You are tasked with using the Metasploit framework to successfully obtain a reverse shell on the remote host using an exploit module.

Suggested Time:
35 Minutes



Time's up!
Let's review



Questions?





Break
15 mins



Post Exploitation



Let's recap

Day 3 Recap

Let's recap what we've covered so far:

We introduced C2 frameworks and learned how pen testers utilize their tools and features to conduct various aspects of pen tests.



We then learned about a popular C2 framework called **Metasploit**, and how it can be used to:

- Search for potential exploits.
- Run the potential exploits.



Getting a shell on a machine is only the first part of having full control over the system.

The last activity you completed was part of the Exploitation phase.

Next, we'll focus on the **Post Exploitation** phase.



Planning and
reconnaissance

Scanning

Exploitation

Post exploitation

Reporting



Phase 4: Post Exploitation

Post Exploitation involves multiple steps, typically used to accomplish the following tasks:

Enumeration



Persistence



**Privilege
escalation**



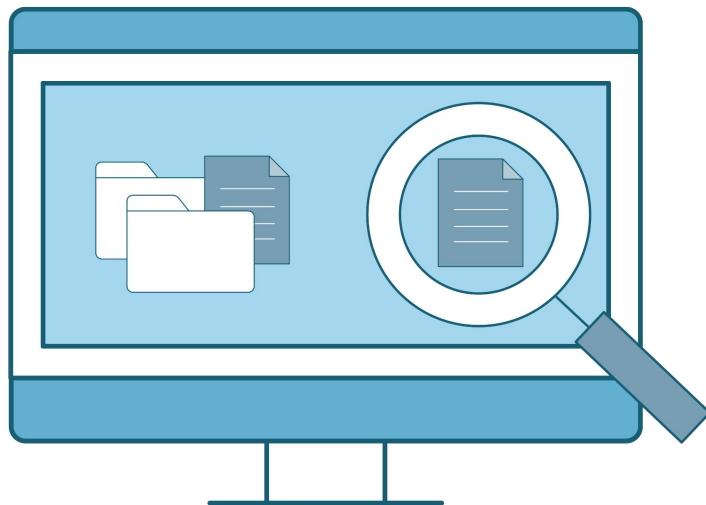
Phase 4: Post Exploitation

Enumeration and Searching for Useful Data

Similar to the enumeration process during the Reconnaissance phase, except we are enumerating and searching for data **from inside** the target after it has been exploited.

This means we search for any useful information that's available from inside the target, including:

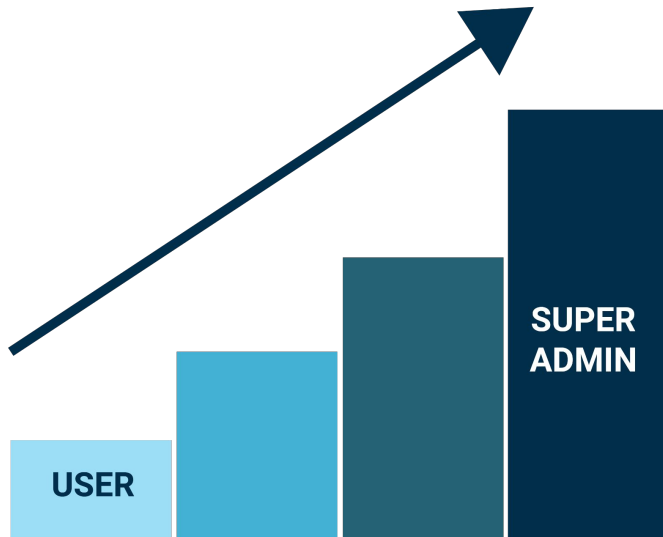
- Current User Context
- List of Users
- Current User Access
- Defensive Countermeasures





Phase 4: Post Exploitation

Persistence and Privilege Escalation



Persistence:

The process of attempting to maintain long-term access to your target.

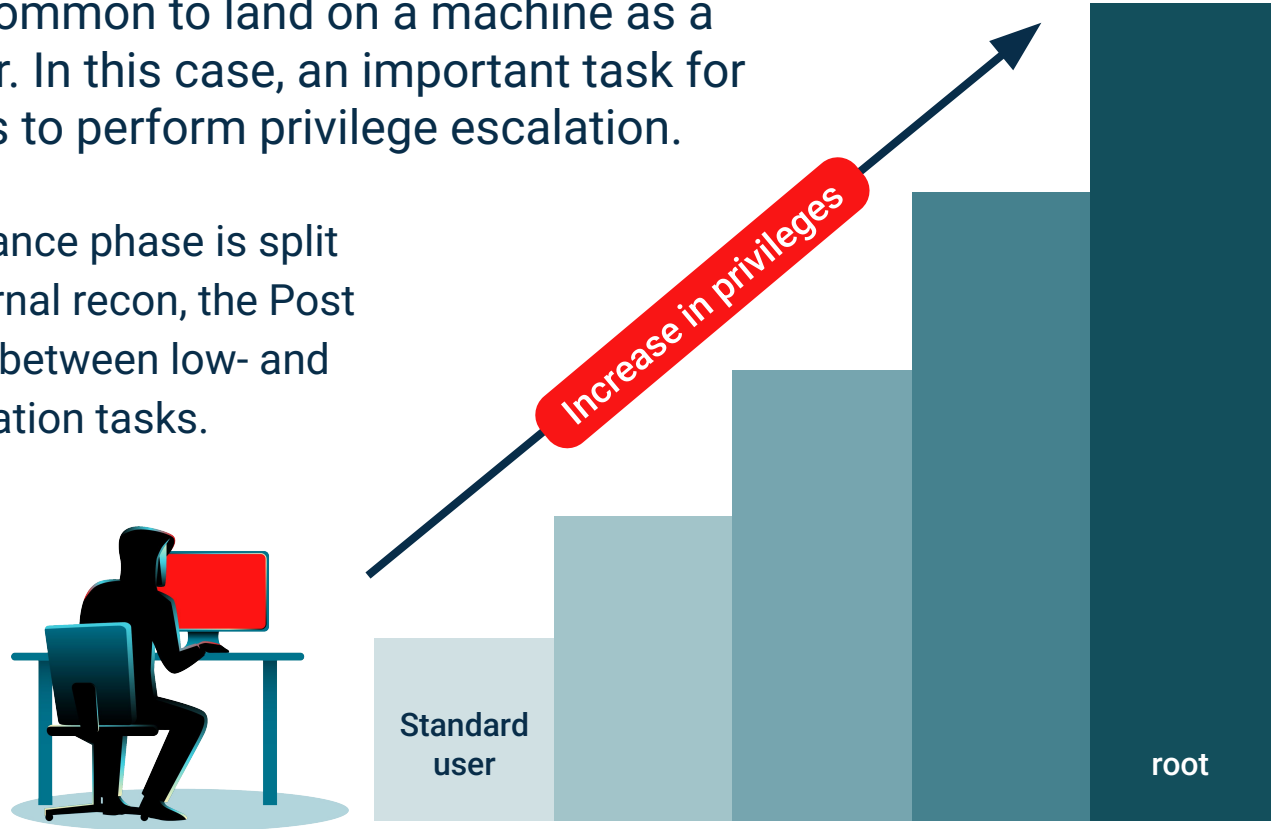
Privilege Escalation:

The process of escalating privileges from a less-privileged user to a more-privileged user (or a low-privilege to high-privilege user).

Privilege Escalation

When pen testing, it's common to land on a machine as a low- or no-privilege user. In this case, an important task for the penetration tester is to perform privilege escalation.

Much like the Reconnaissance phase is split between external and internal recon, the Post Exploitation phase is split between low- and high-privilege post-exploitation tasks.



High- and Low-Privilege Post Exploitation Tasks

Low-privilege tasks

Require minimal permissions and include:

- Gathering system/OS details.
- Gathering services and versions.
- Getting a list of users and groups.

High-privilege tasks

Require `sudo` or `root` privileges and include:

- Reading sensitive files, such as `/etc/shadow` and SSH keys.
- Creating users and assigning them to privileged groups.
- Installing new services.
- The majority of persistence tasks.

Tips for Successful Privilege Escalation

01

Utilize information gathered during enumeration.

02

Use the path of least resistance.

03

Exploit vulnerable software.

Tips for Successful Privilege Escalation

01

Utilize information gathered during enumeration.

Gathering information allows us to identify a potential path to privilege escalation.

Common Linux paths of privilege escalation:

- **Abusing current access**
(e.g., sudo group, writable files, read access to sensitive files)
- **Exploitation of software**
(some services may run as a higher-privileged user)
- **Utilizing weak passwords of privileged users**

Tips for Successful Privilege Escalation

02

Use the path of least resistance.

Search for the easiest possible way to obtain your objective instead of jumping to a difficult task.

For example:

- Some users keep passwords in a text file. Instead of hijacking a user's web browsing session and keylogging their strokes in an attempt to gather passwords, you can just find the text file.
- In addition to being easier, finding passwords in files or abusing functionality (e.g., scripts run as root but world-writable) is also stealthier, which is a key component of red teaming.

Tips for Successful Privilege Escalation

03

Exploit vulnerable software.

Exploitation of vulnerable software is often suggested as a last step due to the nature of privilege-escalation techniques.

- Often it involves abusing a service that has the potential to crash and bring down the machine.
- For this reason, finding as much information as possible on the machine during enumeration is key to help find any other possible privilege-escalation paths.



Phase 4: Post Exploitation

MITRE <> Privilege Escalation

The screenshot shows a web browser displaying the MITRE ATT&CK website. The browser's address bar shows the URL `attack.mitre.org/tactics/TA0004/`. The page features a red header with the MITRE ATT&CK logo and navigation links for Matrices, Tactics, Techniques, Data Sources, Mitigations, and Groups. A search bar is also present. Below the header, a banner for ATT&CKcon 3.0 is visible. The main content area is titled "Privilege Escalation" and includes a breadcrumb trail: Home > Tactics > Enterprise > Privilege Escalation. The text describes the tactic as a method for adversaries to gain higher-level permissions. A sidebar on the left lists various tactics, with "Privilege Escalation" highlighted in red. A box on the right provides metadata for the tactic, including its ID (TA0004), creation date (17 October 2018), and last modified date (06 January 2021). A "Version Permalink" link is also present.

MITRE | ATT&CK

Matrices Tactics Techniques Data Sources Mitigations Groups

Software Resources Blog Contribute Search

ATT&CKcon 3.0 will be March 29, 30 2022 in McLean, VA! Submit to our CFP by 11/23 [here](#)

TACTICS

Enterprise

Reconnaissance

Resource Development

Initial Access

Execution

Persistence

Privilege Escalation

Defense Evasion

Credential Access

Discovery

Lateral Movement

Collection

Command and Control

Exfiltration

Impact

Home > Tactics > Enterprise > Privilege Escalation

Privilege Escalation

The adversary is trying to gain higher-level permissions.

Privilege Escalation consists of techniques that adversaries use to gain higher-level permissions on a system or network. Adversaries can often enter and explore a network with unprivileged access but require elevated permissions to follow through on their objectives. Common approaches are to take advantage of system weaknesses, misconfigurations, and vulnerabilities. Examples of elevated access include:

- SYSTEM/root level
- local administrator
- user account with admin-like access
- user accounts with access to specific system or perform specific function

These techniques often overlap with Persistence techniques,

ID: TA0004

Created: 17 October 2018

Last Modified: 06 January 2021

[Version Permalink](#)

Privilege escalation has its own **MITRE tactic.**

In the next activity, you will attempt to find a way to escalate your privileges from the daemon user to a **higher-privileged user**.

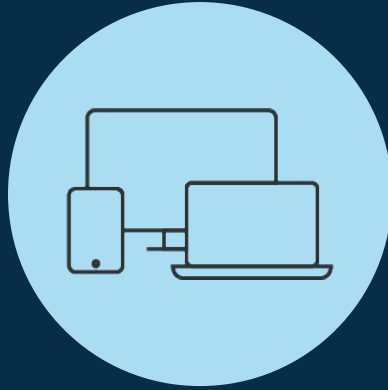
But first, everyone needs to be at the same starting point on the remote machine.

Please follow along with the demonstration to get set up for the next activity.





After the demo, leave the current window and Metasploit session open for the next activity.



Instructor Demonstration

Post Exploitation Activity Setup



Activity:

Metasploit

In this activity, you will continue to play the role of pen testers conducting an engagement on MegaCorpOne.

- You will conduct post-exploitation tasks in order to attempt to gain privilege escalation.

Suggested Time:
20 Minutes





Time's up!
Let's review



Questions?





Next class

Post-Exploitation and Reporting



Thank you